

Consent & Data-Protection Pack

Working draft for the clinic's data-protection adviser to review and sign off

Plain-English summary

This pack turns the clinic's consent capture into something defensible under UK GDPR and PECR as communications move into GoHighLevel. It covers what the enquiry and registration forms should ask, how to capture email and WhatsApp preferences properly, the lawful basis for each activity, the updated list of the systems that touch patient data, and the specific edits the existing privacy policies need. It is written to be handed to your data-protection adviser for final sign-off before anything goes live.

Context we have worked from

- **Jurisdiction:** UK. Clinic established in the UK, CQC registered; patients may be international but require a UK address. Governing regime: UK GDPR + Data Protection Act 2018 + PECR.
- **Data type:** special-category (health) data. Even at enquiry, the "reason for enquiry" can reveal health information, so Article 9 applies from the first touchpoint.
- **Marketing:** email + newsletter (moving from MailChimp to GoHighLevel). WhatsApp is used for the shared inbox and appointment reminders (service), not marketing. Retargeting ads (Google/Facebook/Instagram) are referenced in the current website policy but not confirmed as in use.
- **Controller / processor:** the clinic is the data controller. Semble and GoHighLevel and others are processors acting on the clinic's instructions.

1 · Enquiry-form consent block

The enquiry form collects: name, surname, email, phone, sex at birth, reason for enquiry (drop-down), referral source. Because the reason can reveal health information, capture explicit consent to handle it, then keep marketing separate and optional.

a) Handling your enquiry (required to proceed)

How we will use these details

We use the information you provide to respond to your enquiry and guide you through the next steps. Because your enquiry may include information about your health, we ask for your explicit consent to handle it for this purpose.

☐ **I consent to The Schoeman Clinic using the information in this enquiry, including any health-related details, to respond and help me take the next steps.**

(Unticked by default. See our Privacy Policy for how we look after your information.)

b) Staying in touch (optional, unticked)

How would you like us to contact you about your care?

☐ Email ☐ WhatsApp ☐ SMS / phone

Clinic updates (optional)

☐ I would like to receive clinic news, health information and occasional updates by email.

You can change your preferences or unsubscribe at any time. WhatsApp is used for appointment reminders and service messages, not marketing.

2 · Registration-form consent block

The registration form collects full medical history and identity. For a patient receiving care the basis shifts from consent to contract plus provision of health care, so the wording changes accordingly. Carry the marketing preference across from the enquiry rather than re-asking, unless it was not captured cleanly.

Your information and your care

We use the information on this form to provide your healthcare, keep your medical records, arrange tests and prescriptions, and manage your appointments and billing. We handle your health information under UK GDPR Article 9(2)(h) (provision of health care) and the Data Protection Act 2018.

☐ I confirm the information I have provided is accurate, and I understand how The Schoeman Clinic will use it, as described in the Patient Privacy Policy.

Contact & updates

☐ Email ☐ WhatsApp ☐ SMS / phone (how we contact you about your care)

☐ I would like to receive clinic news and updates by email (optional).

Note for build: replace every “EU GDPR” reference on the Semble registration and consent forms with “UK GDPR”.

3 · Marketing consent — how to capture it

- **Design:** capture explicit, per-channel opt-in ONCE, cleanly, at the enquiry stage, using separate unticked boxes. Do not bundle “email and WhatsApp” into one tick, and do not pre-tick.
- **Separation:** keep marketing (newsletters, clinic updates) clearly separate from service messages (appointment reminders, results logistics). This keeps consent “specific”.
- **Email:** email marketing needs consent or a valid PECR soft opt-in; every send needs a working unsubscribe and a genuine sender identity. Newsletters moving from MailChimp to GoHighLevel must carry only contacts with a valid basis — do not assume the whole patient list is opted in.
- **WhatsApp:** treat any future WhatsApp marketing as needing its own explicit opt-in plus Meta-approved templates. For now WhatsApp stays service-only, which matches Dr Gina’s wish not to

“bombard” patients.

- **Record + fix:** record what each person consented to, when, how, and which version of the notice they saw. Important: Semble currently auto-marks SMS/email consent on registration — that is not valid consent and should be replaced with a genuine opt-in captured as above.

4 • Lawful-basis table

Activity	Lawful basis (Art 6)	Health-data basis (Art 9)
Responding to an enquiry (incl. health reason)	Consent, or legitimate interests	Explicit consent — Art 9(2)(a)
Providing healthcare (records, tests, prescriptions)	Contract — Art 6(1)(b)	Provision of health care — Art 9(2)(h)
Appointment reminders / service messages	Contract / legitimate interests	n/a
Email newsletter / clinic marketing	Consent — Art 6(1)(a) + PECR	n/a
Payment processing	Contract — Art 6(1)(b)	n/a
Website analytics, cookies, retargeting	Consent — PECR (cookie banner)	n/a

5 • Sub-processor register (updated)

Provider	What data	Location	Transfer mechanism
Semble	Clinical records, admin	UK	n/a
GoHighLevel (HIPAA tier)	Operational CRM, inbox, forms, comms	US	UK IDTA in DPA
WhatsApp / Meta Cloud API	Patient messages	GB storage	Meta DPA / adequacy
Stripe	Payment data	UK / EU	n/a / SCCs
The Doctors Laboratory (TDL)	Blood-test data	UK	n/a
Pharmacies (PCCA, Fagron, Zen, Natural Dispensary, Nordic, Vibrant)	Prescription / order data	UK / US	confirm per vendor
Google Analytics / Maps	Website usage	US	confirm (consent-gated)
MailChimp (being retired → GHL)	Newsletter emails	US	confirm / remove on migration

6 · Privacy-notice updates needed

- **Terminology:** replace every “EU GDPR” reference with “UK GDPR” across the Semble registration form, consent form, and both privacy policies.
- **Add processor:** add GoHighLevel as a processor (operational CRM, inbox, forms, communications; US, HIPAA tier, UK IDTA).
- **Add processor:** add WhatsApp / Meta Cloud API as a processor for patient messaging (GB storage).
- **Update:** the website policy names MailChimp for newsletters; update to reflect the move to GoHighLevel (retain MailChimp only if still used).
- **Confirm / fix:** the website policy references retargeting ads via Google, Facebook and Instagram. Confirm whether these are actually in use; if not, remove the clause; if yes, ensure the cookie banner captures consent for them (PECR).
- **Cookies:** ensure a compliant cookie consent banner is in place for non-essential cookies (analytics, maps, any retargeting).
- **Contact:** name a data-protection contact and the subject-access-request route.

7 · Before this goes live — data-person checklist

- ☐ Confirm the lawful bases above for special-category data at enquiry and in care
- ☐ Approve the final enquiry and registration consent wording
- ☐ Confirm the newsletter list only contains contacts with a valid basis before the MailChimp → GHM migration
- ☐ Replace Semble’s auto-marked consent with genuine captured opt-in
- ☐ Sign off the updated sub-processor register and the UK IDTA for GoHighLevel
- ☐ Confirm whether retargeting ads are in use and fix the website policy accordingly
- ☐ Confirm patient “active / inactive / archived” status governs who can be marketed to
- ☐ Update EU → UK GDPR references everywhere

This is a working draft to speed up your compliance process. Have a qualified lawyer or your data-protection adviser in the relevant jurisdiction review and sign it off before it goes live.

Prepared by WILBA for The Schoeman Clinic